

CSW Compliance Mapping — Live Gartner Review Companion Guide

For: Nadir · **Use:** keep this open on a second screen during the live Gartner call **Showcasing:** PCI DSS v4.0 · NERC CIP · HIPAA Security Rule compliance reports **Golden rule for the whole call:** *CSW turns workload communication and inventory into **evidence** an assessor can review. It does **not** certify or "make you" compliant. Say this early; it is what earns analyst credibility.*

0. Pre-call setup (do this 5 minutes before)

- Open these files in this order, in separate tabs:
 1. `index.html` (the landing page — shows the full 34-framework library)
 2. `PCI-DSS-v4/CSW-PCI-DSS-Compliance-Report.pdf`
 3. `NERC-CIP/CSW-NERC-CIP-Compliance-Report.pdf`
 4. `HIPAA/CSW-HIPAA-Compliance-Report.pdf`
 5. One **Technical Runbook** (e.g. `PCI-DSS-v4/CSW-PCI-DSS-Technical-Runbook.pdf`) to prove depth if asked
 - Have the **coverage legend** (Section 2) visible — you will be asked what the colors mean.
 - Share the **specific tab**, not the whole desktop. Zoom to ~125% so tables are readable on the analyst's screen.
 - Have one sentence ready if screen-share fails: "The library maps CSW evidence to 34 frameworks; I'll walk three."
-

1. Opening frame (60–90 seconds, say this once)

"This is a Cisco Secure Workload compliance-mapping library — **34 frameworks**, each with two documents: a **customer-facing report** for compliance and audit teams, and a **technical runbook** for the engineers. Every framework ships as editable DOCX, a review PDF, and browsable HTML.

The honest positioning — and the part your clients care about — is this: CSW doesn't certify compliance. It turns **workload-to-workload communication, inventory, and vulnerability data into assessor-ready evidence**, mapped control-by-control, with a suggested collection cadence. The assessor still makes the call; we make their evidence trivial to produce."

Why this wins with Gartner: analysts reward **honest scope boundaries** over "compliance-in-a-box" claims. Lead with the limitation and you own the room.

2. The coverage legend (explain before the first table)

Every report color-codes each control row by how much evidence CSW produces:

Label	Means	Color
Direct / Full Coverage	CSW produces the primary evidence artifact for this control	Green
Supporting / Partial Coverage	CSW produces evidence that sits <i>next to</i> another control/tool	Amber
Evidence Required / Out of scope	CSW has no record; the customer evidences it elsewhere (policy, HR, physical, crypto, identity)	Red

Say explicitly: "Green means CSW *produces the artifact* — **not** that the control is automatically passed. That distinction is deliberate."

3. Report walkthroughs — Open → Show → Say → Expect

3A. PCI DSS v4.0 (*≈5 min*)

Open: CSW-PCI-DSS-Compliance-Report.pdf

Show 1 — Control Coverage Summary table. Say: "CSW directly supports the five requirements most cited in PCI findings — **Req 1 network controls, 6 vulnerability mgmt, 7 access, 10 logging/monitoring, 11 security testing.** Workload-level micro-segmentation isolates the CDE at the OS, not just the perimeter — which is the QSA's main lateral-movement concern."

Show 2 — CDE scope segmentation table (CDE / CDE-Connected / Out-of-Scope / Third-Party Processors). Say: "This is how we scope the cardholder data environment and *prove* isolation with ADM — default-deny inbound, allowlist-only outbound."

Show 3 — QSA Evidence Package table. Say: "Every row is an export a QSA can request directly — policy export, flow logs, vuln reports — with a frequency. That's the time-saver."

Honest boundary (say it): "Req 3/4 encryption, Req 8 identity/MFA, Req 9 physical, Req 12 policy are **Evidence Required** — not CSW. We show that in red."

3B. NERC CIP (*≈5 min — the IT/OT framing is everything*)

Open: CSW-NERC-CIP-Compliance-Report.pdf

Show 1 — Compliance Posture Summary (CIP-002 → CIP-014). Say: "Critical framing: CSW is the **IT-side** evidence engine. It is **Direct** on **CIP-005 electronic security perimeter (IT-side)**, **CIP-007 ports/services & monitoring**, and **CIP-010 configuration baseline & vuln assessment** — the audit-heavy ones. It is **Supporting** on CIP-002/003/009/011, and **Out of scope** for CIP-004 personnel, CIP-006/014 physical."

Show 2 — Control Coverage Summary (what CSW produces / what the entity still files). Say: "CIP-010 is the standout — a **daily software and listening-port baseline with diff and disposition**. A change seen here with no change ticket is your unauthorized-change candidate."

Honest boundary (say it, unprompted): "CSW is **not** the Electronic Access Point firewall, and it does **not** touch the **OT device layer** — PLCs, RTUs, protocols like DNP3/Modbus. That's an OT-native tool like **Cyber Vision**. CSW covers the IT-side workloads: historians, jump hosts, the IT/OT DMZ." (*This honesty is exactly what a Gartner analyst is probing for.*)

3C. HIPAA Security Rule (≈5 min)

Open: CSW-HIPAA-Compliance-Report.pdf

Show 1 — Compliance Posture Summary: Administrative §164.308 **Full**, Physical §164.310 **Partial**, Technical §164.312 **Full**, Organizational §164.314 **Evidence Required**.

Show 2 — HIPAA Control Mapping Detail (Technical Safeguards §164.312). Say: "At the ePHI tier CSW maps cleanly: **audit controls** (full flow + process telemetry), **integrity**, **authentication** (enforces LDAPS/Kerberos-only, blocks plain LDAP 389), and **encryption-in-transit detection** — we flag HTTP/FTP/plain-LDAP on the PHI zone."

Show 3 — Evidence Collection & Audit Readiness table. Say: "Eight evidence artifacts, each tied to a HIPAA control and a cadence — this is the audit-readiness kit."

Honest boundary (say it): "§164.314 Business Associate contracts, physical safeguards, and encryption *enforcement* are **Evidence Required** — CSW **detects** plaintext but doesn't encrypt; identity and BAAs live elsewhere."

4. Gartner-specific angles (weave in where natural)

- **Breadth + consistency:** 34 frameworks on one evidence model — including zero-trust (NIST 800-207, CISA ZTMM), sector (NERC, TSA, IEC 62443), and regional (DORA, NIS2, APRA, MAS).
 - **Two-audience design:** report for GRC/auditors, runbook for engineers — same control spine, different depth.
 - **Continuous vs point-in-time:** evidence is produced continuously (flows, policy drift), replacing once-a-year sampling.
 - **Alignment to Gartner's microsegmentation guidance:** OS-level, identity-/label-based segmentation; ADM → simulation → enforce lifecycle.
-

5. Likely analyst questions — crisp answers

- **"Does this certify compliance?"** → "No. It produces assessor-ready evidence inputs; the qualified assessor determines status."
 - **"How is this better than a written mapping?"** → "Each row ties to a live CSW export with a cadence, plus a paired engineering runbook, consistent across 34 frameworks."
 - **"NERC — what about OT?"** → "IT-side only by design; pair with Cyber Vision for the OT device layer. We state that explicitly in the report."
 - **"Agent coverage gaps?"** → "Anything we can't instrument goes on a documented *cannot-instrument register* — which is itself audit evidence."
 - **"Encryption?"** → "CSW detects plaintext flows; it does not enforce encryption. Shown as Evidence Required."
 - **"How current are the mappings?"** → "Each report has a version note; validate against the version the customer is assessed under."
 - **"Enforcement risk in production?"** → "ADM builds the policy, run in **simulation** ≥2 weeks, then enforce. No big-bang."
-

6. Close / ask (last 60 seconds)

"The goal is to make microsegmentation evidence a non-event for compliance teams across whatever framework a client is assessed against."

Ask Gartner for: (1) feedback on framework coverage/gaps worth adding, (2) whether this fits relevant research (microsegmentation, CNAPP/CWPP, zero-trust), (3) intros to clients who keep asking "prove segmentation for my audit."

7. Timing & guardrails

For a 25–30 min slot: 2 min open · 5 min PCI · 5 min NERC · 5 min HIPAA · 2 min breadth · ~6–8 min Q&A.

Do: lead with the evidence-not-certification line; name the red/out-of-scope rows out loud; keep to three reports. **Don't say:** "CSW makes you PCI/HIPAA/NERC compliant," "replaces your QSA/auditor," or "covers OT." **Do say:** "produces assessor-ready evidence," "complements identity/crypto/physical controls," "IT-side."

Disclaimer to have ready: these reports are informational planning aids, not legal/audit/certification advice; validate mappings against the official framework text and the customer's assessed version.